certora

Security Assessment
Final Report

Kvault- Redeem in Kind

02.2026

Prepared for Kamino finance

Table of contents

Project Summary 3
Project Scope 3
Project Overview 3
Protocol Overview 3
Findings Summary 4
Severity Matrix 5
Detailed Findings 6
Medium Severity Issues 7
M-01 Missing Minimum Withdraw Amount Check 7
Low Severity Issues 8
L-01 Missing Mint Validation on cToken Vault Account 8
Informational Issues 9
I-01. Unnecessary Rounding in Withdrawal Penalty Calculation 9
Disclaimer 10
About Certora 10

Project Summary

Project Scope

Project Name	Repository (link)	Latest Commit Hash	Platform
Kvault	https://github.com/Kamino-Finance/kvault-private/pull/59	5f8c2	Solana
Kvault	https://github.com/Kamino-Finance/kvault-private/pull/113	4b66b	Solana

Project Overview

This document describes findings discovered during a manual code review. The work was undertaken from **04.01.2026** to **08.01.2026** & **11.02.2026.**

The scope includes changes made in the mentioned PRs under **programs/kvault/src** directory:

Protocol Overview

"Add redeem in kind operation" introduces a new feature allowing users to redeem their vault shares directly for cTokens (Kamino Lending
collateral tokens) instead of going through the standard withdrawal flow that returns the underlying liquidity token. The flow calculates the user's
entitled liquidity based on their share proportion of AUM, applies withdrawal fees, converts the net amount to cTokens (capped at vault balance), and
transfers them to the user while burning shares.

Findings Summary

The table below summarizes the findings of the review, including type and severity details.

Severity	Discovered	Fixed
Critical	0	0
High	0	0
Medium	1	1
Low	1	1
Informational	1	1
Total	3	3

Severity Matrix

Impact	High	Medium	High	Critical
	Medium	Low	Medium	High
	Low	Low	Low	Medium
		Low	Medium	High
		Likelihood		

Detailed Findings

ID	Title	Severity	Status
M-01	Missing Minimum Withdraw Amount Check	Medium	Fixed
L-01	Missing Mint Validation on cToken Vault Account	Low	Fixed

Medium Severity Issues

M-01 Missing Minimum Withdraw Amount Check		
Severity: **Medium**	Impact: **Medium**	Likelihood: **Medium**
Files: programs/kvault/src/operations/vault_operations.rs	Status: Fixed	

Description: The standard `withdraw` path enforces `min_withdraw_amount`, rejecting redemptions below a configured threshold. The new `redeem_in_kind` path omits this check entirely, allowing dust redemptions that bypass the intended minimum.

Recommendations: Introduce `min_withdraw_amount` check in the new flow

Customer's response: Fixed in PR#94.

Fix Review: Fix confirmed.

Low Severity Issues

L-01 Missing Mint Validation on cToken Vault Account		
Severity: **Low**	Impact: **Low**	Likelihood: **Low**
Files: programs/kvault/src/handlers/handler_redeem_in_kind.rs	Status: Fixed	

Description:

The `ctoken_vault` PDA account used in the `redeem_in_kind` handler lacks an explicit mint constraint. While the PDA seeds derivation and the `user_ctoken_ta` mint check make exploitation unlikely in practice, adding a direct mint validation on the `ctoken_vault` account provides defense-in-depth.

Recommendations: Add a mint validation.

Customer's response: Fixed in PR98.

Fix Review: Fix confirmed.

Informational Issues

I-01. Unnecessary Rounding in Withdrawal Penalty Calculation

Description:
`get_withdrawal_penalty_for_fraction_amount_inclusive()` rounds its result to `u64` before the caller immediately converts it back to a `Fraction`. This intermediate rounding loses precision and wastes compute units.
The same issue applies to `get_withdrawal_penalty_for_fraction_amount_exclusive()`

Recommendation: The suggested refactor is to have `get_withdrawal_penalty_for_fraction_amount_inclusive()` return a `Fraction` directly, with rounding deferred to the public-facing `get_withdrawal_penalty()` which operates on integer amounts.

Customer's response: Fixed in PR98.
Fix Review: Fix confirmed

Disclaimer

Even though we hope this information is helpful, we provide no warranty of any kind, explicit or implied. The contents of this report should not be construed as a complete guarantee that the contract is secure in all dimensions. In no event shall Certora or any of its employees be liable for any claim, damages, or other liability, whether in an action of contract, tort, or otherwise, arising from, out of, or in connection with the results reported here.

About Certora

Certora is a Web3 security company that provides industry-leading formal verification tools and smart contract audits. Certora's flagship security product, Certora Prover, is a unique SaaS product that automatically locates even the most rare & hard-to-find bugs on your smart contracts or mathematically proves their absence. The Certora Prover plugs into your standard deployment pipeline. It is helpful for smart contract developers and security researchers during auditing and bug bounties.

Certora also provides services such as auditing, formal verification projects, and incident response.